UNIT 4 · TOPIC 4.4

Endpoint Threat Auditing

Quiz

Instructions: This quiz has 18 multiple-choice questions, 1 point each. Circle the letter of the single best answer for each question.

Name: **Date:** **Class:**

1. A security analyst wants to monitor activities on a single workstation for signs of attack originating on or targeting that machine. Which type of tool is specifically designed to detect attacks by monitoring events on the host device itself?

- ○ A. Network-based Intrusion Detection System (NIDS)
- ○ B. Web Application Firewall (WAF)
- ○ C. Host-based Intrusion Detection System (HIDS)
- ○ D. Packet analyzer

2. In the context of device security, which term describes observable evidence found on or produced by a host that suggests a security incident may have occurred or be in progress?

- ○ A. Vulnerability
- ○ B. Threat vector
- ○ C. Attack surface
- ○ D. Indicator of Compromise (IoC)

3. An administrator reviews an authentication log and finds 350 failed login attempts targeting the "admin" account from the same IP address, all occurring within a two-minute window. Which attack does this pattern most clearly indicate?

- ○ A. SQL injection
- ○ B. Brute-force password attack
- ○ C. Cross-site scripting (XSS)
- ○ D. Man-in-the-middle (MITM) attack

4. Dynamic's security team wants to ensure that any unauthorized modification to executable files on its manufacturing-network workstations is detected as quickly as possible. Which detection control is most appropriate for this specific requirement?

- ○ A. Deploy a network-based IDS to monitor all ingress traffic at the manufacturing network boundary
- ○ B. Enable file integrity monitoring (FIM) on the workstations
- ○ C. Configure a web application firewall on the manufacturing subnet gateway
- ○ D. Install a mail gateway to filter phishing attachments before delivery

5. A security team wants to both detect and limit the damage from brute-force password attacks against manufacturing workstation accounts. Which combination of controls best addresses both goals simultaneously?

- ○ A. Firewall rules and antivirus scanning
- ○ B. Patch management and vulnerability scanning
- ○ C. Full-disk encryption and VPN access control
- ○ D. Account lockout policies and authentication log monitoring

6. Dynamic's security team needs to correlate authentication log events from 40 manufacturing workstations to identify coordinated attack patterns across the environment. Which detection strategy is most scalable and effective for this requirement?

- ○ A. Manually review each workstation's local log file on a daily schedule
- ○ B. Install a standalone HIDS on each workstation with no central aggregation or correlation
- ○ C. Deploy a Security Information and Event Management (SIEM) system to centralize log collection and apply correlation rules
- ○ D. Rely on each endpoint's antivirus alert notifications independently

7. Dynamic's security architect proposes two detection strategies for the manufacturing network: (A) deploy HIDS agents on every workstation, or (B) deploy a single NIDS at the perimeter where the manufacturing network connects to the business network. The threat scenario is an attacker who has already gained a foothold in the business network and may attempt lateral movement into manufacturing. Which statement most accurately evaluates the limitations of the perimeter-only NIDS strategy for this scenario?

- ○ A. A perimeter NIDS is superior because it requires fewer licensing costs than HIDS agents on every endpoint.
- ○ B. A perimeter NIDS will generate fewer false positives than HIDS because it only sees traffic crossing the boundary, making it strictly preferable.
- ○ C. A perimeter NIDS cannot detect attacks originating from within the manufacturing network or carried over encrypted channels, leaving critical blind spots in this specific threat scenario.
- ○ D. A perimeter NIDS is sufficient because all attacks from the business network must traverse the boundary sensor before reaching manufacturing endpoints.

8. Dynamic's security team is choosing between a signature-based endpoint detection tool and a behavioral anomaly detection tool for its manufacturing workstations. A colleague argues that since the threat involves a persistent adversary from a prior breach, behavioral detection is strictly preferable and signatures can be dropped entirely. Which evaluation of this argument is most accurate?

- ○ A. The argument is correct; behavioral tools fully replace signature-based detection in all environments.
- ○ B. The argument is incorrect only because behavioral detection tools are too computationally expensive to run on industrial workstations.
- ○ C. The argument overstates the case: while behavioral detection is better suited to novel or persistent threats, signature tools efficiently catch known malware families with near-zero false positives, a defense-in-depth approach using both is more effective than either alone.
- ○ D. The argument is correct for detecting novel attacks, but behavioral tools cannot classify any known attack types.

9. During post-incident review, Dynamic's forensic team discovers that authentication logs needed to reconstruct the full attack timeline were overwritten: the default retention period was 24 hours, and the attack occurred 9 days before the investigation. The security team had real-time alerting in place during the attack window but no analyst acted on the alerts. Which evaluation of this outcome is most accurate?

- ○ A. The detection strategy was adequate; real-time alerting fulfills the detection requirement and log retention is only an administrative concern.
- ○ B. The failure was purely a staffing issue; the detection strategy itself was sound, and additional security personnel would have resolved both problems.
- ○ C. The detection strategy was doubly flawed: the alert-fatigue problem indicates the alerting configuration lacked sufficient tuning or prioritization, and the absence of adequate log retention eliminated forensic reconstruction capability, effective detection strategy must address both real-time response and evidence preservation.
- ○ D. Log retention is irrelevant if real-time alerting is functional, since all necessary information is captured at alert generation time.

10. Which type of password attack is characterized by systematically trying every possible character combination, including letters, numbers, and symbols, until the correct password is found?

- ○ A. Dictionary attack
- ○ B. Rainbow table attack
- ○ C. Brute-force attack
- ○ D. Credential stuffing

11. A HIDS generates an alert because an unknown process on a manufacturing workstation is making repeated outbound connection attempts to an external IP address on an unusual port. This behavior is most consistent with which type of attack?

- ○ A. Denial-of-service (DoS) attack against an external target
- ○ B. Command-and-control (C2) communication by malware installed on the device
- ○ C. SQL injection against a web application
- ○ D. Physical hardware tampering

12. In an authentication log, which entry pattern most clearly indicates a successful unauthorized access following a brute-force attack?

- ○ A. A single failed login followed by no further activity from that IP address
- ○ B. Hundreds of failed login attempts from one IP address, immediately followed by a successful login from that same IP
- ○ C. Multiple successful logins from a user's usual device at the usual time of day
- ○ D. One failed login followed immediately by a password reset request originated by the user

13. You are a forensic analyst at Dynamic, reviewing authentication logs for the manufacturing network after a suspected lateral-movement attempt from the compromised office network. You observe the following events on workstation MFG-07 over a 10-minute window:

02:14:01, FAILED user:"admin" src:10.0.1.45
02:14:03, FAILED user:"administrator" src:10.0.1.45
02:14:05, FAILED user:"root" src:10.0.1.45
[224 additional FAILED entries targeting common username variants, src:10.0.1.45]
02:23:58, SUCCESS user:"mfg_svc" src:10.0.1.45

Which classification and next step are most appropriate?

- ○ A. Normal scheduled maintenance activity; the service account login at 02:23 is expected. No action required.
- ○ B. Phishing attack; notify the owner of the "mfg_svc" account to change their password and re-enable the account.
- ○ C. Dictionary attack against common default usernames, successful on account "mfg_svc"; treat the successful login as a critical IoC, lock the account, and investigate post-authentication activity on MFG-07.
- ○ D. Denial-of-service attack; block 10.0.1.45 at the perimeter firewall and close the incident.

14. Reviewing authentication logs for Dynamic's manufacturing network, you find the following events targeting workstation MFG-12 over a 45-minute period:

09:01:14, FAILED user:"mfg_ops" src:10.0.1.22 password_tried:"Password1"
09:19:47, FAILED user:"mfg_ops" src:10.0.1.31 password_tried:"Summer2023!"
09:44:02, FAILED user:"mfg_ops" src:10.0.1.19 password_tried:"Welcome1"

Which attack type does this log pattern most likely represent, and why?

- ○ A. Brute-force attack, because multiple passwords are being tried against the same account
- ○ B. Keylogger-based credential theft, because the attacker knows which specific passwords to try
- ○ C. Rainbow table attack, because the passwords attempted are common and precomputed hashes exist for them
- ○ D. Password spray attack, because a small set of commonly used passwords is being tried slowly from multiple source IPs to stay below account lockout thresholds

15. When analyzing authentication log files to identify indicators of a password attack against manufacturing workstations, which combination of log fields should a forensic analyst prioritize correlating?

- ○ A. Source IP address, event timestamp, login success/failure status, and targeted username
- ○ B. Username, file hash, and CPU usage at time of event
- ○ C. Destination TCP port, DNS query name, and network interface MAC address
- ○ D. Process ID, memory usage at event time, and disk write rate

16. Dynamic is evaluating an AI-assisted Endpoint Detection and Response (EDR) tool that uses a machine learning classifier trained on historical attack datasets to automatically classify device attacks. A senior engineer argues the tool should replace human analyst review entirely, since AI detection is faster, more consistent, and never fatigued. Which evaluation of this argument is most accurate?

- ○ A. The argument overstates AI capability: ML classifiers can produce false positives and false negatives, are constrained by their training distribution, and cannot apply organizational context, human analysts remain essential for validation, triage, and response authorization, particularly in a manufacturing environment where incorrect automated action carries operational risk.
- ○ B. The argument is correct; modern AI-based EDR tools have achieved sufficient accuracy to eliminate the need for human analysts in all incident classification tasks.
- ○ C. The argument is incorrect primarily because AI tools are too expensive for manufacturing environments and should be replaced by cheaper rule-based detection.
- ○ D. The argument is partially correct: AI tools can detect novel attacks perfectly but cannot classify any known attack types, so human analysts should handle only known-attack classification.

17. After completing log analysis for Dynamic's manufacturing network, the forensic analyst reports that authentication logs alone were insufficient to fully classify the scope and impact of the attack, they could confirm that a service account was compromised but could not determine what the attacker did afterward. Which evaluation of the detection method's impact most accurately explains this limitation?

- ○ A. Authentication logs are not a valid source for incident response; only full network packet captures provide reliable evidence.
- ○ B. Authentication logs are fully sufficient for attack classification when log timestamps are accurately synchronized across hosts.
- ○ C. The limitation arose because the logs were stored in plain text format, which made the post-authentication entries unreadable.
- ○ D. Authentication logs accurately record credential-based attack events but have an inherent scope boundary: they do not capture post-authentication behavior, so they cannot alone classify what an attacker did after gaining access, full attack classification requires correlating authentication logs with process, file access, and network flow data.

18. Dynamic's security team deployed signature-based antivirus as the sole detection mechanism on all manufacturing endpoints, believing it would provide comprehensive coverage. During a subsequent incident investigation, analysts discovered the attacker used a fileless technique, injecting malicious code into a legitimate

running process using native OS scripting tools, with no malicious file ever written to disk. Which evaluation of the detection strategy's impact is most accurate?

- ○ A. The strategy was sound; signature-based antivirus is the industry-standard endpoint control and covers all modern attack techniques.
- ○ B. The strategy was appropriate for a manufacturing environment because fileless attack techniques are rare in operational technology contexts and were unlikely to be encountered.
- ○ C. The impact was limited because fileless attacks cannot persist across system reboots, so reimaging the workstations would have resolved the compromise without needing detection.
- ○ D. The strategy had a fundamental blind spot: signature-based antivirus scans file artifacts on disk and cannot detect fileless attacks that operate entirely in memory or inject into legitimate processes, detecting this class of attack requires behavioral monitoring or memory-analysis capabilities such as those provided by EDR solutions.